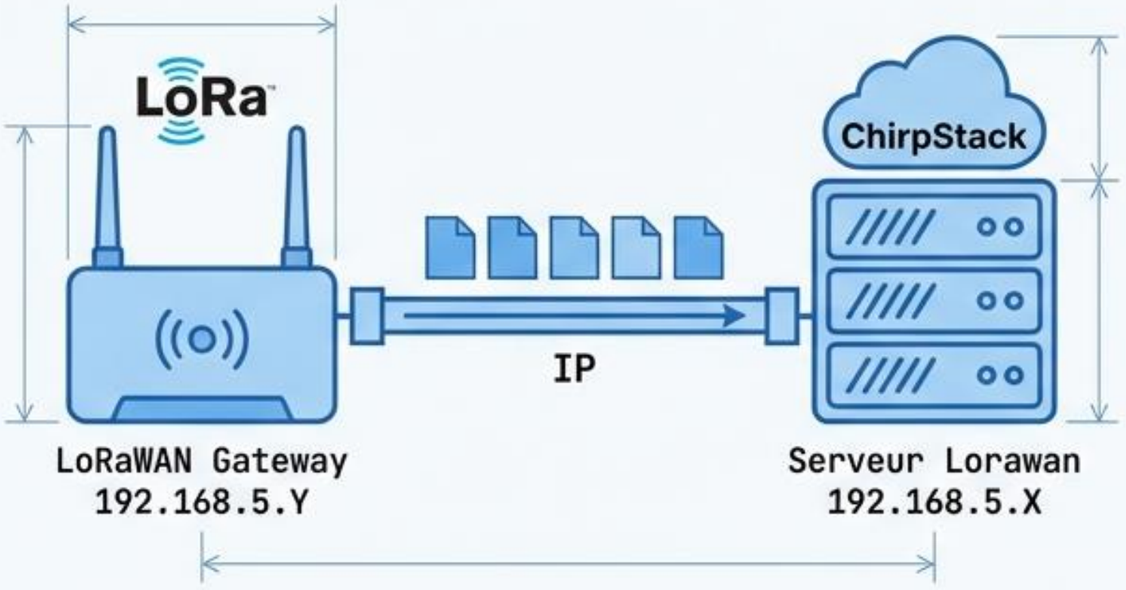
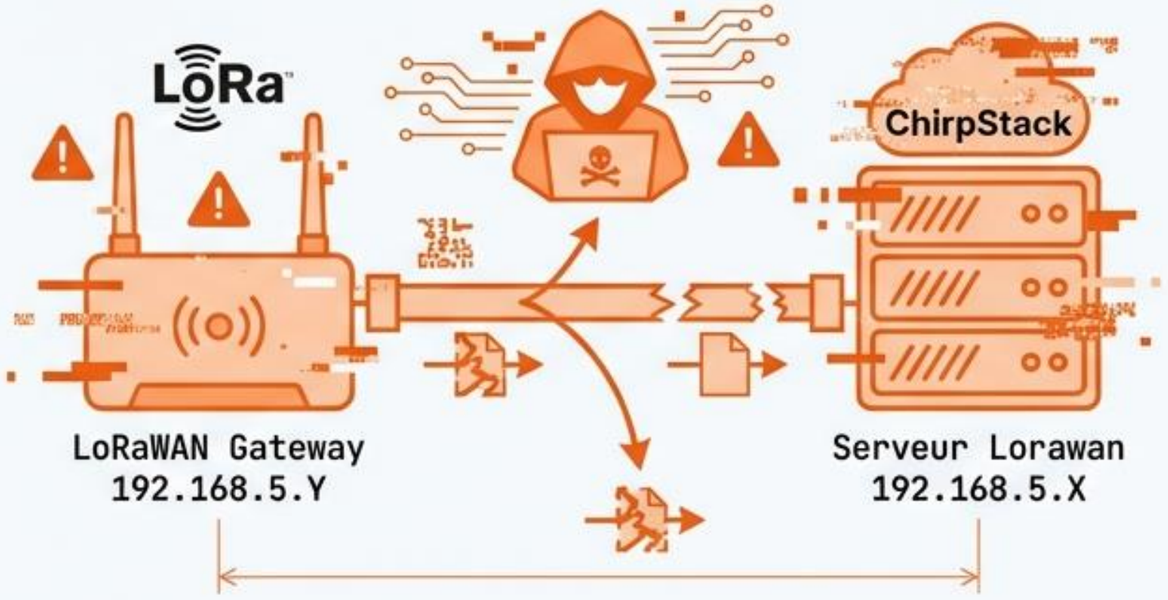
Audit de Sécurité LoRaWAN : Construction et Compromission

De la configuration de l'infrastructure à l'analyse forensique des paquets

CONSTRUCTION PHASE

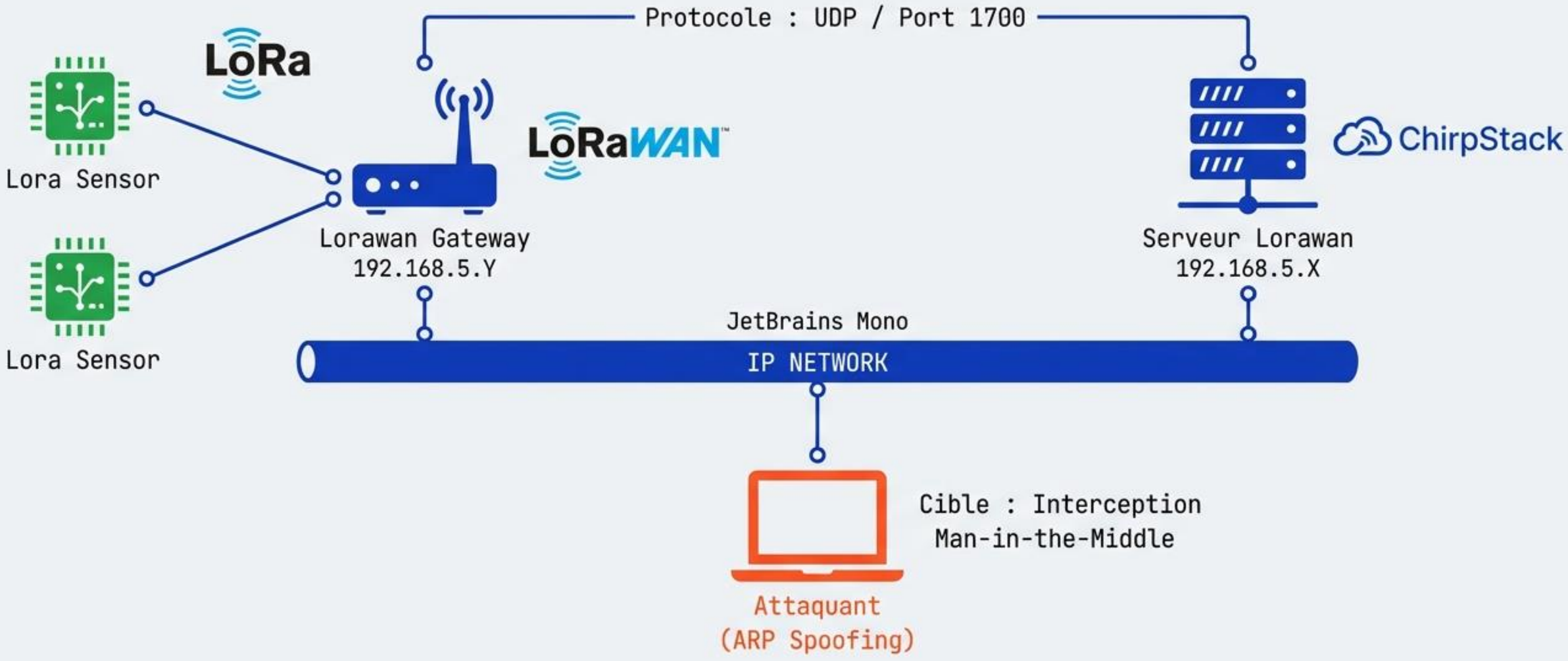


COMPROMISSION PHASE



Objectif : Déployer un réseau privé, intercepter le trafic UDP, et briser le chiffrement.

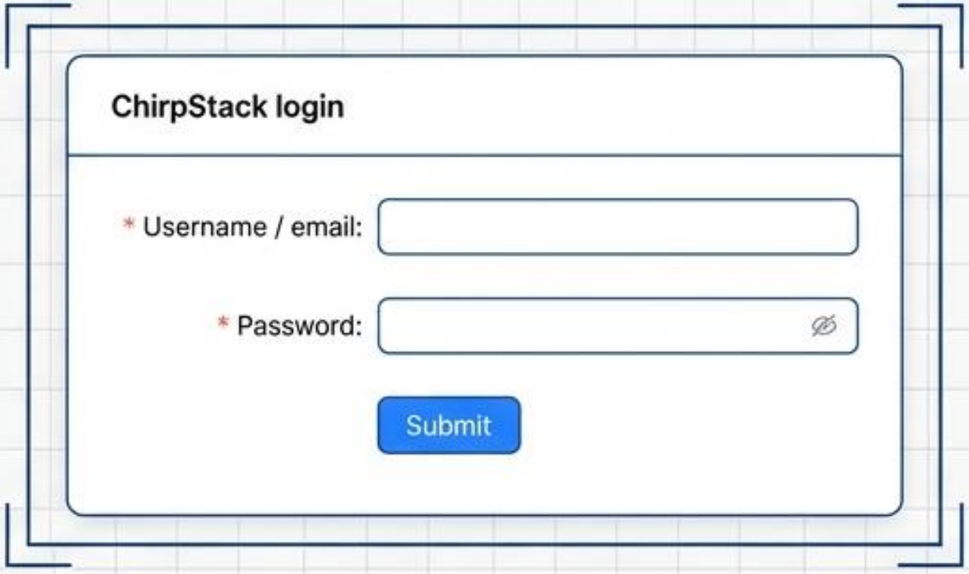
Topologie du Réseau et Vecteur d'Attaque



Phase 1 : L'Infrastructure (Le Serveur)

TERMINAL - CHIRPSTACK

```
> git clone https://github.com/chirpstack
/chirpstack-docker.git
> cd chirpstack-docker
> docker-compose up -d
```

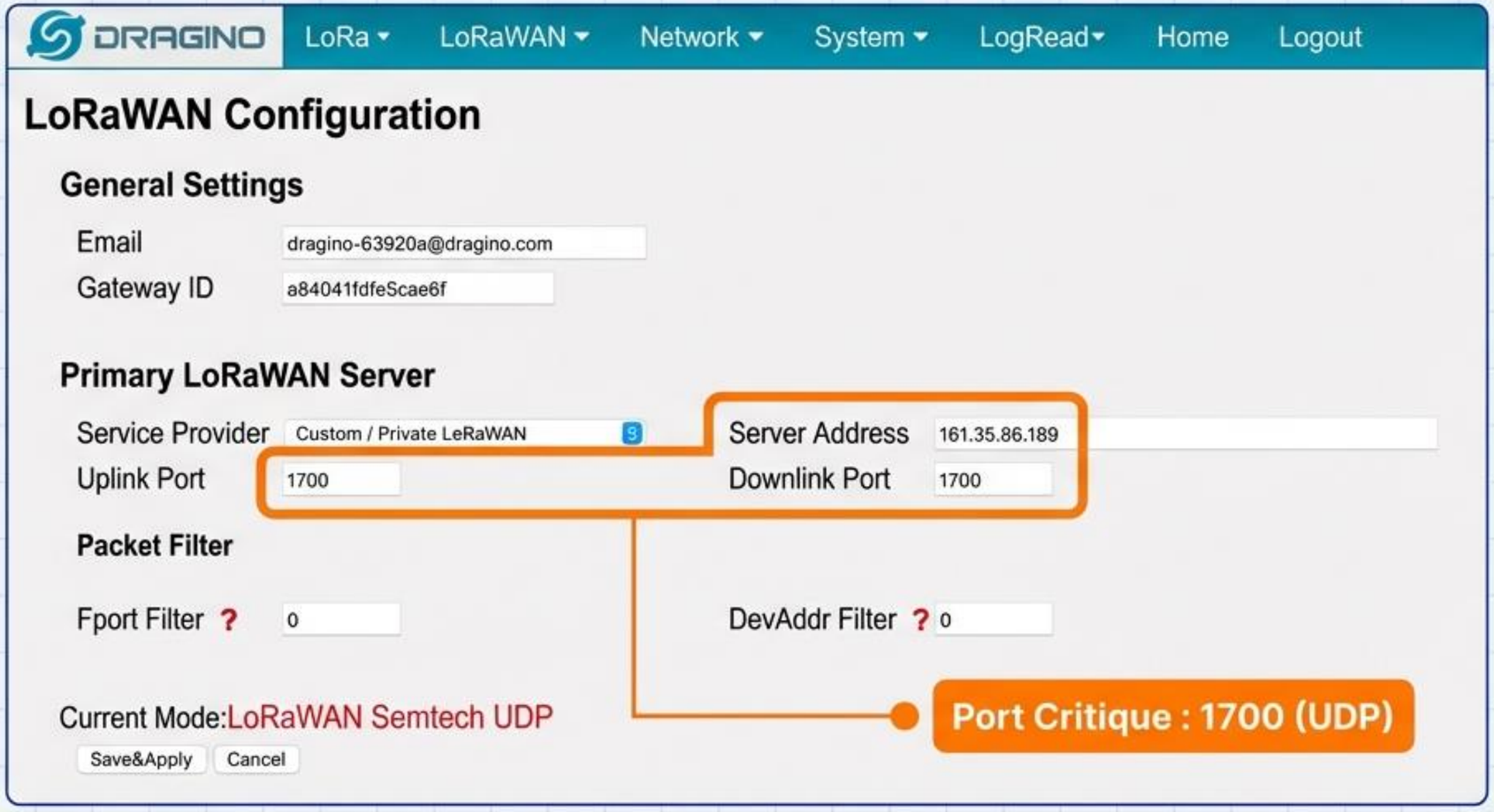


Déploiement :
Stack Docker complète (Network Server, App Server, Gateway Bridge)

Accès :
Interface web sur port 8080

Identifiants :
admin / admin

Phase 1 : La Passerelle (Le Point d'Entrée)



Rôle : Packet Forwarder (Transfert de paquets)

Protocole : LoRaWAN Semtech UDP

Vulnérabilité : Le trafic UDP est non chiffré sur le réseau local (LAN).

Provisioning du Device (Arduino MKR 1310)

Arduino IDE

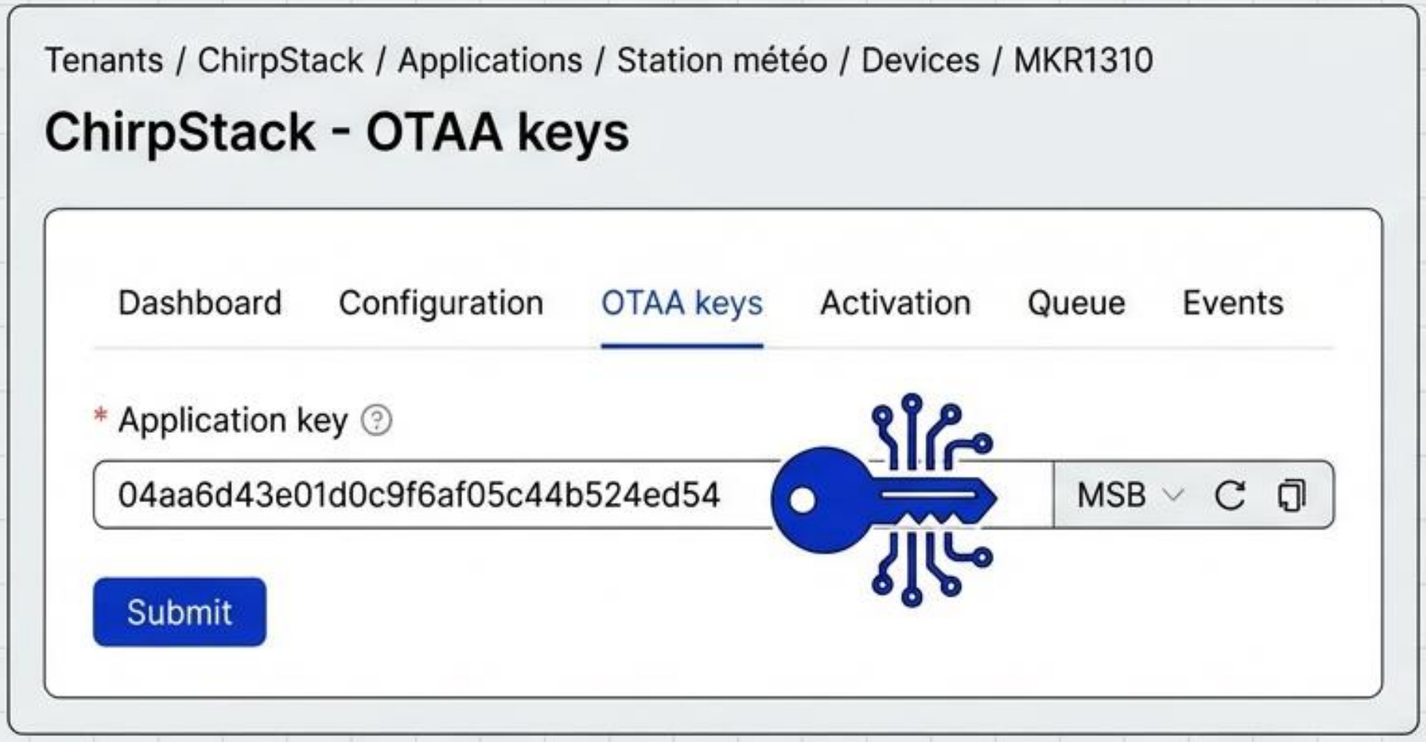
```
#include <MKRWAN.h>

devEUI = a8610a3233428e03
...
```

ChirpStack Server

Matériel :
Arduino MKR WAN 1310

Identité :
Device EUI (Identifiant unique 64-bit)

La Racine de la Confiance : AppKey & OTAA



- **Méthode d'activation :** OTAA (Over-The-Air Activation)
- **AppKey :** Clé racine AES-128
- **Sécurité :** Cette clé ne transite jamais en clair sur le réseau après l'initialisation.

Validation du Flux Uplink

Arduino IDE Serial Monitor

```
Enter a message to send to network
(make sure that end-of-line 'NL' is enabled)

Sending: Hello Lora
```

ChirpStack Server Event Log

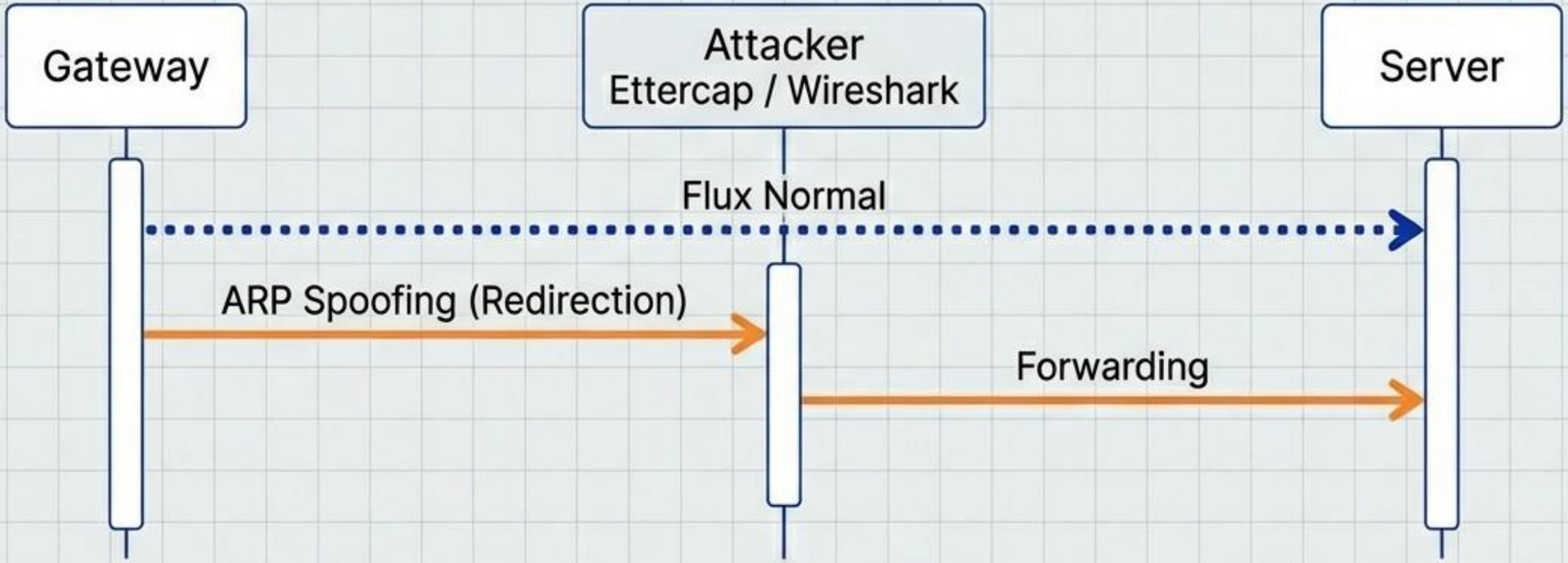

```
{
  "deduplicationId": "d5bce951-a
  "time": "2024-02-14T09:24:17.0
  "deviceInfo": {
    "tenantId": "52f14cd4-a0ba-e
    "applicationName": "Station météo",
    "deviceName": "MKR1310",
    "devEui": "a8610a3233428e03"
  },
  "confirmed": true,
  "data": "SGVsbG8gTG9yYQ==",
  "rxInfo": [{
      "gatewayId": "c0ee40ffff2a3fed",
      "rssi": -49,
      "snr": 8.2,
      "channel": 7
    }]
```


État : Confirmé (ConfirmedDataUp)

Decoding

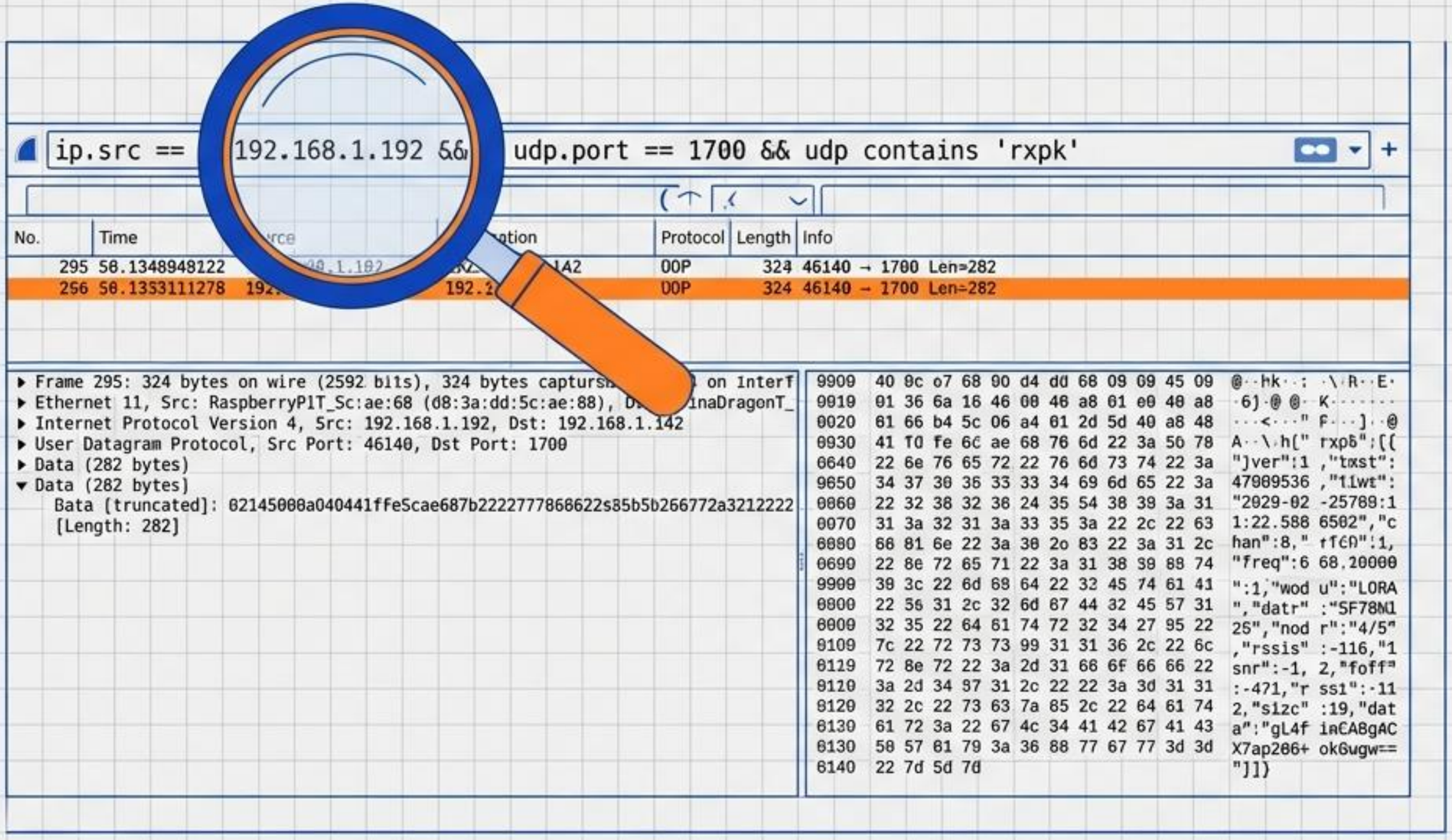
Base64: SGVsbG8gTG9yYQ== -> ASCII: Hello Lora

Phase 2 : L'Attaque Man-in-the-Middle (MitM)



Technique : Empoisonnement du cache ARP
Commande : `ettercap -T -i eno1 -M arp:remote /IP_Gateway/ /IP_Server/`
Effet : L'attaquant intercepte tout le trafic UDP port 1700.

Sniffing et Capture (Wireshark)



- **Filtre :** Isolation du trafic UDP LoRaWAN
- **Cible :** Objet JSON 'rxpk' (Receive Packet)
- **Résultat :** Capture des trames brutes avant le serveur.

Extraction du Payload Chiffré


```
{
    "rxpk": [
        {
            "jver": 1,
            "tmst": 47009536,
            "time": "2026-02-25T09:11:21.538650Z",
            "chan": 0,
            "rfch": 1,
            "freq": 868.100000,
            "mid": 8,
            "stat": 1,
            "modu": "LORA",
            "datr": "SF7BW125",
            "codr": "4/5",
            "rssis": -116,
            "lsnr": -1.2,
            "foff": -471,
            "rssi": -112,
            "size": 19,
            "data": "gL4f iwCABgACX7apZ06+ok8wgw=="
        }
    ]
}
```


Payload Chiffré (AES-128)

*Format :** JSON encapsulé dans UDP
Problème : Illisible sans les clés de session (NwkSKey, AppSKey).

Les Clés de Session (Le Graal)

SENSITIVE DATA

Network Session Key (NwkSKey): `37c62d724830f98288a8c372ffc330be` ← Assure l'intégrité (MIC)

App Session Key (AppSKey): `c3d87c85d7300975c418137396a397f8` ← Assure la confidentialité (Déchiffrement)

Phase 3 : Déchiffrement (Preuve de Concept)

LoRa Packet Decoder

LoRa Packet : `gL4f iwCABgACX7apZ06+ok8wgw==`

AppSKey : `c3d87c85d7300975c418137396a397f8`

NwkSKey : `37c62d724830f98288a8c372ffc330be`

DECODE

Opération : Validation du MIC et déchiffrement AES-CTR.

Résultat de l'Analyse Forensique

LoRa Packet Decoder Result

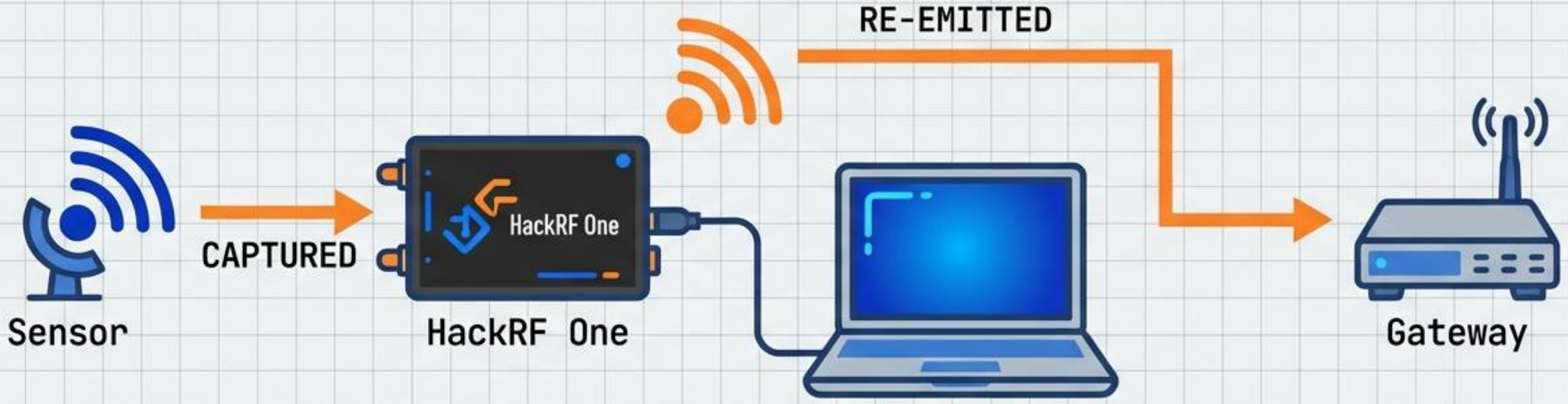
```
Encoded = base64

Message Type = Data
PHYPayload = 80BE1F8B00800600025FB6A9674EBEA24F3083

( PHYPayload = MHDR[1] | MACPayload[..] | MIC[4] )
    MHDR = 80
    MACPayload = BE1F8B00800600025FB6A9674EBE
    MIC = A24F3083 (from packet)

( MACPayload = FHDR | FPort | FRMPayload )
    FHDR = BE1F8B00800600
    FPort = 02
    FRMPayload = 5FB6A9674EBE (Encrypted)
               = 4E6577746F6E (Decrypted)

( FHDR = DevAddr[4] | FCtrl[1] | FCnt[2] | FOpts[0..15] )
    DevAddr = 008B1FBE
    FCtrl = 80
    FCnt = 0006
    FOpts =

...
```

TEXTE CLAIR : Newton

La confidentialité est brisée dès lors que les clés de session sont compromises.

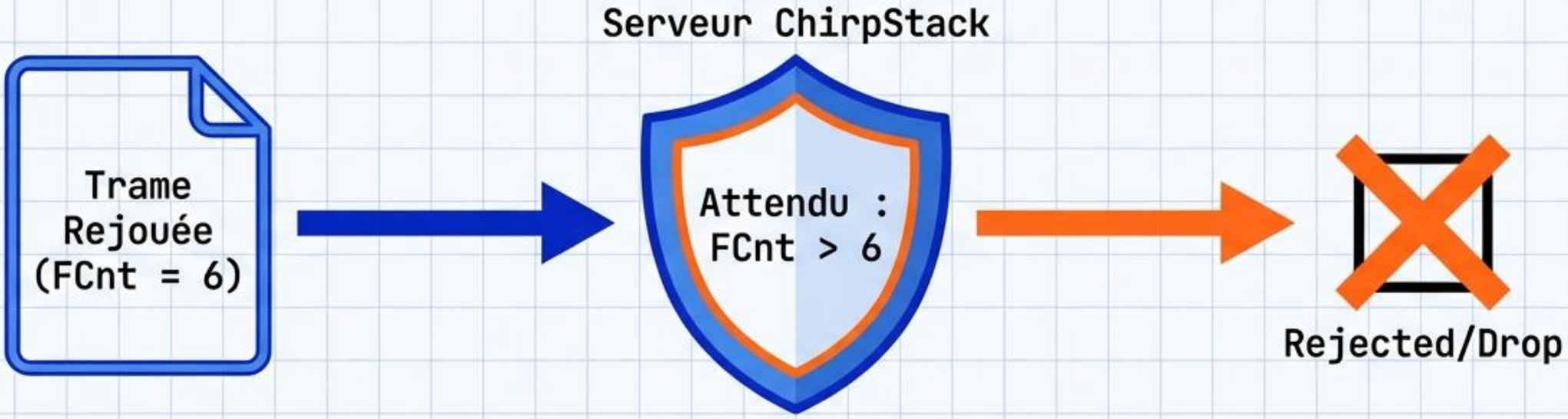
Technical Forensic Blueprint

Menace Avancée : Attaque par Rejeu (Replay)



- **Matériel** : SDR (Software Defined Radio) - HackRF One
- **Méthode** : Capture IQ et réémission brute
- **Objectif** : Duper le serveur avec une ancienne trame valide.

La Défense : Compteur de Trames (Frame Counter)




```
( FHDR   = DevAddr[4] | FCtrl[1] | FCnt[2] | FOpts[0..15] )
  DevAddr = 008B1FBE (Big Endian)
  FCtrl   = 80
  FCnt    = 0006 (Big Endian)
  FOpts   =
```

Le serveur rejette tout paquet dont le compteur (FCnt) est inférieur ou égal au dernier reçu. Protection native contre le rejeu.